MARLOW BASIN WATER DISTRICT

Information Security Office

ISP-07: Information Security Policy for Third-Party Vendors

Version	3.2
Effective date	January 1, 2026
Policy owner	Chief Information Security Officer
Approved by	Ruth Calloway, Chief Information Officer
Review cycle	Annual. Next review December 2026.
Applies to	All vendors, contractors and subprocessors that store, process or access District data or systems

Revision history

Version	Date	Summary of changes
3.0	2024-07-01	Restructured policy; added data classification and mobile device sections
3.1	2025-03-15	Added automated deprovisioning requirement (Section 4.3)
3.2	2026-01-01	Added artificial intelligence restrictions (Section 5.4); shortened incident notification windows (Section 6.1)

1. Purpose

This policy establishes the minimum security requirements that third-party vendors must meet when they store, process, transmit or access data owned by the Marlow Basin Water District (the "District"), or connect to District systems. As operator of critical drinking water infrastructure, the District must protect information whose disclosure could endanger public health and safety.

2. Scope and Applicability

This policy applies to all contracts, purchase orders and agreements under which a vendor handles District data, including software-as-a-service (SaaS) providers and their subprocessors. Requirements in this policy are incorporated by reference into District contracts. Where a contract and this policy conflict, the more protective requirement applies unless the CISO has granted an exception under Section 10.

3. Data Classification

3.1 District data is classified into four levels: Public, Internal, Internal-Restricted and Confidential. Vendors shall protect data according to its classification.

3.2 Unless the District specifies otherwise in writing, the following classifications apply:

Data type	Classification
Published reports, water quality summaries	Public
General business correspondence, schedules	Internal
Field inspection records, asset condition data, work orders, photos of distribution assets	Internal-Restricted
Customer personal information and billing data	Confidential
Locations, layouts and security details of treatment plants, pump stations and reservoirs (critical infrastructure)	Confidential
Credentials, encryption keys, network diagrams	Confidential

3.3 A dataset that contains any Confidential element is treated as Confidential in its entirety.

4. Identity and Access Management

4.1 Vendor applications used by District personnel shall support single sign-on through the District identity provider using SAML 2.0 or OpenID Connect. Local application passwords for District users are not permitted.

4.2 Multi-factor authentication shall be enforced for all District users and for all vendor personnel with administrative or support access to District data.

4.3 **Automated provisioning and deprovisioning.** For any vendor application with more than 50 District users, user accounts shall be provisioned and deprovisioned automatically from the District identity provider using SCIM 2.0 or an equivalent automated integration approved by the CISO. Access for separated personnel shall be revoked **within 24 hours** of separation. Manual processes, including

periodic file uploads, do not satisfy this requirement.

4.4 Vendors shall implement role-based access control and shall provide the District with a report of all user accounts and roles on request, and at least quarterly.

5. Data Protection

5.1 District data shall be encrypted at rest using AES-256 or stronger and in transit using TLS 1.2 or higher. Deprecated protocols and cipher suites shall be disabled.

5.2 **Key management.** For data classified as Confidential, encryption keys shall be **customer-managed**: keys shall be generated and held in a key management service controlled by the District, and the District shall be able to revoke the vendor's access to those keys at any time. Vendor-managed keys are acceptable for Internal and Internal-Restricted data.

5.3 Production District data shall not be copied to development or test environments unless it has been irreversibly de-identified.

5.4 **Artificial intelligence.** Vendors shall not process District data using third-party generative artificial intelligence services, and shall not use District data to train, fine-tune or evaluate any artificial intelligence model, without **prior written approval from the CISO**. Features that send District data to such services shall be disabled for the District by default. Processing by models that run entirely within the vendor's own environment shall be disclosed in the vendor's security response.

6. Security Incident Response

6.1 **Notification.** Vendors shall notify the District Information Security Office of any security incident that affects or may affect District data or systems **within 72 hours of discovery**. Where the incident involves Confidential data, notification shall be made **within 24 hours of discovery**. Notification shall be made by phone to the District security hotline and in writing to security@mbwd.example.

6.2 The initial notification shall describe the nature of the incident, the data and systems affected, and containment actions taken. Vendors shall provide updates at least every 48 hours until the incident is resolved and a written root cause report within 30 days.

6.3 Vendors shall cooperate with District investigations and with any notifications the District is required to make to regulators or the public.

7. Data Retention, Location and Return

7.1 Field inspection records and associated photos shall be retained for a minimum of **seven (7) years** from creation, or longer if required by a legal hold.

7.2 Within 30 days after contract termination, vendors shall return all District data in a documented, non-proprietary format and provide a written certification of deletion from all systems, including backups, within a further 30 days.

7.3 **Data location and access.** District data shall be stored and processed only in data centers located in the continental United States. Vendor personnel located outside the United States shall not access District production data, including through support sessions, unless approved in writing by the CISO.

8. Assurance and Oversight

8.1 Vendors shall provide a SOC 2 Type II report, or equivalent independent assessment approved by the CISO, covering the services provided to the District. Reports shall be provided annually.

8.2 Vendors shall commission an independent penetration test of the services at least annually and provide the District with a summary of findings and remediation status.

8.3 Vendors shall maintain a current list of subprocessors and shall notify the District at least 30 days before adding a subprocessor that will process District data.

8.4 The District reserves the right to audit vendor compliance with this policy on 30 days' notice, no more than once per year except following a security incident.

9. Mobile Devices and Offline Data

9.1 Vendor mobile applications that store District data on devices shall encrypt that data and shall support remote wipe initiated by the District.

9.2 **Offline data lifetime.** District data cached on a mobile device shall be automatically purged if the device has not completed a successful synchronization for **14 days**.

9.3 Mobile applications shall not store District data in locations accessible to other applications on the device, including shared photo libraries.

10. Exceptions

10.1 A vendor may request an exception to a specific requirement of this policy in writing. The request shall describe the requirement, the reason for the exception, compensating controls and a remediation plan with dates.

10.2 The CISO may grant a time-limited exception of up to **180 days**. Exceptions may be renewed once. Exceptions to Sections 5.2 (key management) and 6.1 (incident notification) for Confidential data will not be granted.

10.3 Approved exceptions shall be documented in the contract or in a written amendment.

11. Enforcement

Failure to comply with this policy may result in suspension of access to District data and systems, termination of the contract for cause, and other remedies available to the District under the contract or law.

12. Contacts

Role	Contact
Information Security Office	security@mbwd.example
Security hotline (24x7)	(555) 014-7700
Chief Information Security Officer	Arturo Velasquez